

Information Security Controls

Safeguarding Data and Systems

Overview

- access controls,
- integrity controls,
- personnel,
- policies,
- protocols (HTTPS, IPsec)

Information Security Controls

- Information security controls are essential measures and strategies that organizations implement to protect their valuable data and systems from various threats.
- **Why are Information Security Controls Crucial?**
 - In today's interconnected digital world, sensitive information is constantly at risk from cyberattacks, data breaches, and other security threats.
- **Purpose of Information Security Controls:**
 - serve as safeguards that reduce the risk of such incidents by protecting the confidentiality, integrity, and availability of data and systems.

Access Controls

- Access controls are a fundamental aspect of information security that involves regulating who or what can access resources in a computing environment.

Types of Access Controls

- **Mandatory Access Control (MAC):**

- MAC enforces strict access policies based on labels or security clearances.
 - The U.S. Department of Defense's Trusted Computer System Evaluation Criteria (TCSEC), commonly known as the Orange Book, defines levels of access based on security classifications.

- **Discretionary Access Control (DAC):**

- DAC allows resource owners to determine access permissions.
 - In a Windows file system, a file owner can specify who can read, write, or execute the file.

- **Role-Based Access Control (RBAC):**

- RBAC assigns permissions based on job roles or functions.
 - In a healthcare system, nurses may have access to patient records, while doctors have additional access rights, all based on their roles.

Examples of Access Control Mechanisms

- **User Authentication**

- Examples: Username and password, biometric authentication (fingerprint, facial recognition), two-factor authentication (2FA).

- **Access Control Lists (ACLs)**

- ACLs are lists of permissions attached to a resource (e.g., a file or a network share) that specify which users or system processes are granted access and what operations they can perform.

- **Role-Based Permissions**

- Assigning permissions to user roles simplifies access management.
- Example: A financial system might have roles like "Manager," "Accountant," and "Auditor," each with different levels of access.

Importance of Access Controls

- Prevents unauthorized access and data breaches.
- Protects sensitive information and maintains data confidentiality.
- Ensures compliance with privacy regulations

Challenges of Access Control

- Balancing security with usability - overly strict controls can hinder productivity.
- Managing access for a large number of users and resources.
- Adapting to changing roles and personnel within an organization.

Integrity Controls

- Integrity controls are measures and safeguards put in place to ensure that data remains accurate, reliable, and unaltered during processing or storage.

Methods of Ensuring Data Integrity

- **Hash Functions:**
- Hash functions generate a fixed-size string of characters (hash value) from data of arbitrary size.
- E.g. SHA-256 (part of the SHA-2 family) generates a 256-bit hash value. Even a small change in the input data results in a significantly different hash value
- Link for more explanation :
<https://corporatefinanceinstitute.com/resources/cryptocurrency/hash-function/>

Hash Functions: Demo

<https://hash-file.online/>

<https://www.fileformat.info/tool/hash.htm>

Hash file online

1

Select a file to hash

Select a file to hash from your system

Browse...

Timetable.docx

2

Choose your hash function

☐ MD5 | 128-bit

☐ SHA-1 | 160-bit

☒ SHA-256 | 256-bit

☐ SHA-512 | 512-bit

3

Launch the hashing process

Launch hash process

Your file hash :

1bbed236effc44e496d8cf948fdce9b88126da42bb4de51bc5b3d00a53236200

@Allan Ninyesiga 2023

one-way function Hash

- Hashing is generally a **one-way function**, which means that it is easy to convert a message into a hash but very difficult to “reverse hash” a hash value back to its original message as it requires a massive amount of computing power.
- This difficulty is what cryptocurrencies like [Bitcoin](#), which uses proof-of-work systems, depend on to ensure the integrity of their [blockchain](#).

Methods of Ensuring Data Integrity

- **Digital Signatures**

- Digital signatures are cryptographic techniques that provide authentication and data integrity.
- When you digitally sign an email or document, it proves that the content has not been altered since the signature was applied, and it verifies the sender's identity.

Methods of Ensuring Data Integrity

- **Write-Once, Read-Many (WORM) Storage:**
- WORM storage devices allow data to be written once and read many times, preventing alterations or deletions.
- E.g: Optical discs, like CD-Rs and DVD-Rs, are WORM storage media often used for archiving critical data.

Real-World Application

- In the context of a financial system, data integrity controls would ensure that transaction records are not altered maliciously or accidentally:
- Hash values can be used to verify the integrity of financial transaction logs.
- Digital signatures can authenticate financial reports submitted to regulatory authorities.

Personnel Controls

- Employees are often the first line of defense in information security. They can either strengthen or weaken an organization's security posture.
- Conduct regular training sessions to educate employees about common security threats like phishing emails and social engineering.
- Teach them how to identify and respond to potential security risks.

Personnel Controls- User Access Reviews

- Regularly reviewing and updating user access privileges can prevent unauthorized access.
 - Conduct periodic reviews to ensure that employees have access only to the resources necessary for their job roles. Remove unnecessary access promptly.
- **Real-World Application**
- In a healthcare organization, personnel controls would involve various measures:
 - Training medical staff to safeguard patient records and follow HIPAA regulations.
 - Conducting background checks on employees who handle sensitive patient information.
 - Defining roles and responsibilities for IT administrators responsible for securing electronic health records.

Security Policies

- Security policies are formal rules and guidelines that organizations establish to protect their information assets and manage security-related activities.
- Security policies serve as a foundation for an organization's overall security strategy, providing clarity, consistency, and a framework for decision-making.

Examples of Security Policies

- **Acceptable Use Policy (AUP):**

- Defines acceptable and unacceptable behavior when using organizational resources.
- E.g: An AUP may prohibit employees from using company computers for personal online shopping or accessing non-work-related websites during business hours.

- **Password Policy:**

- Specifies password requirements, including complexity, expiration, and reuse rules.
- E.g: A password policy may mandate that employees use passwords that are at least 12 characters long, contain a mix of upper and lower-case letters, numbers, and special characters, and must be changed every 90 days.

- **Data Classification Policy:**

- Defines how different types of data should be classified based on sensitivity.
- E.g: A data classification policy may categorize data as public, internal, confidential, and highly confidential, each with corresponding access and handling rules.

Policy Compliance & Training

- **Enforcement and Compliance:**

- Security policies are effective when consistently enforced and monitored for compliance.
 - Regular audits and assessments ensure that employees adhere to password policies, and non-compliance is addressed promptly.

- **Security Awareness Training:**

- Policies should be communicated to all employees through training and awareness programs.
 - Conduct regular workshops to educate employees about the importance of data classification and how to handle different types of data.

Protocols - HTTPS

- *HTTPS (Hypertext Transfer Protocol Secure)*
- HTTPS is a secure version of the Hypertext Transfer Protocol (HTTP), which is used for transmitting data between a web server and a web browser.

HTTPS- Key Features

- **Data Encryption (SSL/TLS):**

- HTTPS uses cryptographic protocols like SSL (Secure Sockets Layer) or TLS (Transport Layer Security) to encrypt data exchanged between the client (web browser) and the server.
- E.g.: When you access a banking website and see "https://" in the URL and a padlock symbol, it indicates that your data is encrypted during transmission.

- **Secure Communication:**

- HTTPS ensures that data exchanged between the client and server remains confidential and cannot be intercepted by malicious actors.
- E.g.: When you log in to your email account or make an online purchase, HTTPS protects your login credentials and payment information.

Benefits of HTTPS

- **Protection of Data in Transit:**

- HTTPS encrypts data during transmission, safeguarding it from eavesdropping and interception.
 - Preventing attackers from capturing login credentials when using public Wi-Fi.

- **Authentication of Websites:**

- HTTPS verifies the authenticity of websites through digital certificates issued by trusted Certificate Authorities (CAs).
 - Ensuring that you are connecting to the genuine website of your bank and not a phishing site.

- **Preventing Eavesdropping:**

- HTTPS prevents attackers from monitoring or altering data being transmitted between the client and server.
 - Safeguarding the confidentiality of healthcare records sent between a patient and a hospital's web portal.

Protocols - IPsec

- *IPsec (Internet Protocol Security)*
- IPsec is a suite of protocols used to secure Internet Protocol (IP) communications by encrypting and authenticating each data packet transferred between devices in a network.

IPsec -Key Features

- **Network Layer Security:**

- IPsec operates at the network layer (Layer 3) of the OSI model, providing security for all traffic between devices within a network.
- E.g.: Protecting data exchanged between branch offices of a multinational corporation over the public internet.

- **Encryption and Authentication:**

- IPsec uses encryption algorithms to ensure confidentiality and authentication mechanisms to verify the identity of communicating devices.
- E.g.: Encrypting sensitive patient data transmitted between a hospital's branch clinics and the central data center.

Benefits of IPsec:

- **Secure Communication Between Network Devices:**

- IPsec secures data in transit between routers, gateways, and other network devices, preventing unauthorized access.
 - Securing communication between remote offices and a central corporate network.

- **Protection Against Unauthorized Access:**

- IPsec helps prevent eavesdropping and man-in-the-middle attacks by encrypting data and verifying the authenticity of communicating devices.
 - Safeguarding financial transactions between a bank's ATM and its data center.

- **Data Confidentiality and Integrity:**

- IPsec ensures that data remains confidential and unaltered during transmission, reducing the risk of data breaches.
 - Protecting confidential business contracts exchanged between partner organizations.

Summary- Recap of Key Points

- **Access Controls:**
 - Access controls regulate who or what can access resources in a computing environment.
 - Examples include user authentication, access control lists (ACLs), and role-based access control (RBAC).
- **Integrity Controls:**
 - Integrity controls ensure data remains accurate, reliable, and unaltered during processing or storage.
 - Methods include hash functions, digital signatures, and WORM storage.
- **Personnel Controls:**
 - Personnel controls involve training, clearances, and defined roles and responsibilities for employees.
 - Security awareness programs educate employees about security threats and best practices.
- **Security Policies:**
 - Security policies are formal rules and guidelines that define acceptable behavior and requirements for information security.
 - Examples include acceptable use policies (AUPs), password policies, and data classification policies.
- **Protocols (HTTPS and IPsec):**
 - HTTPS ensures secure web communication through data encryption and authentication.
 - IPsec secures network communications by encrypting and authenticating data at the network layer.

Summary- Recap of Key Points

- **Examples for Reinforcement:**

- Access controls are like the locks on the doors of your house. They determine who can enter and what rooms they can access.
- Think of integrity controls as the tamper-evident seal on a food package. If it's broken, you know the contents may have been altered.
- Personnel controls are like having security personnel at the entrance of a building, checking IDs and ensuring only authorized people enter.
- Security policies are akin to traffic rules; they set the guidelines for how everyone should behave on the road to ensure safety.
- HTTPS is like sending a letter in a locked box, ensuring that only the recipient can open and read it.
- IPsec is like a secure tunnel between two places. Data passing through the tunnel is protected from prying eyes and alterations.

Q&A

- Any Quests